IKT214 Exam -2021

Question 1

The Basics of Information Security (20%)

a. How Parkerian Hexad model differs from the CIA triad? (2%)

The Parkerian hexad adds three additional attributes, i.e., possession or control, authenticity, and utility, to the three classic security attributes of the CIA triad (confidentiality, integrity, availability).

b. Often, we see that organizations install firewalls, employ skilled security operators to manage intrusion protection systems, and deploy antivirus programs to secure their network infrastructures. What is the purpose of such security arrangements, and why is it important? (2%)

The main purpose of adopting such a multi-layered defensive mechanism is to ensure Defense in Depth. If one mechanism fails, another steps up immediately to prevent an attack.

This multi-layered approach is critical for organizations in order to protect valuable data and information.

c. How the Bell-LaPadula security model differs from the Biba security model? (3%)

The Bell–LaPadula model focuses on data confidentiality and controlled access to classified information, in contrast to the Biba Model which describes rules for the protection of data integrity.

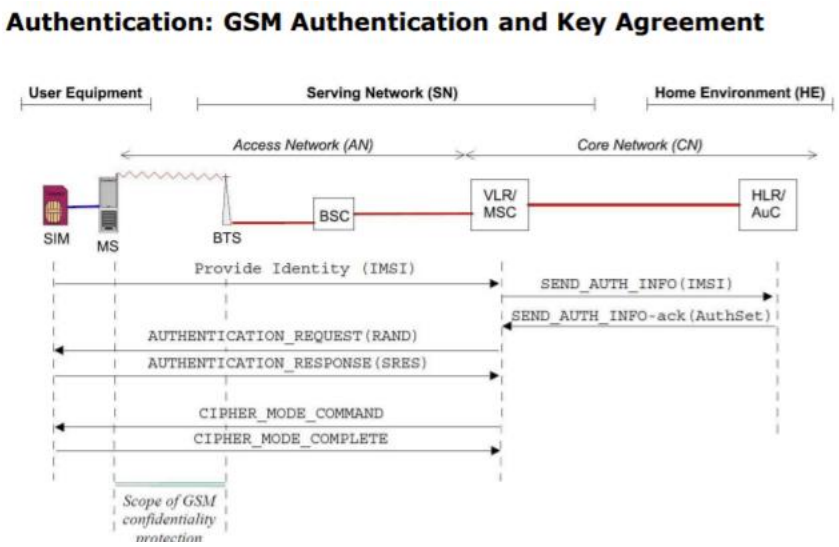
In short, the Biba model is characterized by the phrase: "read up, write down". This differs from the Bell-LaPadula model, which is captured by the phrase "read down, write up".

d. Suppose device A is communicating with device B. An intruder device E overhears the communication between A and B. What threat does such communication encounter and how to prevent that? (2%)

From the provided example it is clear that communication between A and B suffers from the eavesdropping threat.

The communication between A and B should be encrypted to prevent such threats.

e. How is Authentication and Key Agreement (AKA) used for authentication in GSM? Explain briefly. (3.5%)



Authentication in GSM is aided by A3 and A8 (also known as A38). The authentication steps are as follows:

1. At first, the Mobile Station (MS) sends its identity information (IMSI) to the serving network (SN).
2. After authenticating identity, the SN sends an authentication request to the MS using RAND.
3. As soon as MS receives RAND, it takes RAND as input to the A3 algorithm and generates SRES. Then, the MS exchanges SRES with the SN as an authentication response.
4. The SN validates the SRES using the A3 algorithm and uses the A8 algorithm for generating the session cipher key CK. The key CK is then used with the A5 algorithm for encrypting the data over the radio channel between the base stations of the SN and the MS.

f. Suppose you have given two biometric systems - A and B. System A has a GAR of 99.9% and a FAR of 4%. System B has a GAR of 97% and a FAR of 2.5%. Which system is better suited to be used for authentication purposes? Give reasons to support your answer. (2%)

System B is better suited for authentication purposes than system A.

This is due to the reason that unauthorized persons are dangerous or not safe to the system. If FAR is high, the chance of admitting the number of unauthorized persons into the system is also high. In this case, the FAR of system A is greater than system B. Therefore, system B is preferable over system A.

g. What is the difference between Access Control Lists (ACLs) and Capability Lists (C-Lists)? From the below access control matrix, how to construct ACLs and C-Lists for users X and Y? (3.5%)

	Heath data	Personal data
User X	rwx	---
User Y	rw	rx

Access control list is a list for each object containing the domains with a set of access rights for that specific object whereas a capability list is a list of objects and the operations permitted on those objects for each domain.

ACL (Health Data): {(User X, rwx), (User Y, rw)} and ACL (Personal Data): {(User X, ---), (User Y, rx)}

CL (User X): {(Health Data, rwx), (Personal Data, ---)} and CL (User Y): {(Health Data, rw), (Personal Data, rx)}.

h. Is it much easier to solve the confused deputy problem with C-Lists in comparison to ACLs? Give reasons. (2%)

It is easier to solve the confused deputy problem with CLs compared to ACLs because of delegation.

To illustrate the reason we can use the below access control matrix.

	Compiler	BILL
Alice	x	—
Compiler	rx	rw

If ACL is used, Alice can trigger the compiler to write/modify BILL. However, It is not possible with C-List.

With C-List, Alice needs to pass the capability to the output file to the compiler in order to write/modify it. Since Alice lacks a capability to the BILL, it cannot designate that file for output.

Question 2

Cyber Security (20%)

a. Explain how to encrypt and decrypt the message "GRIMSTAD". (4%)
The formula of encryption: $E_n = (X_i + n)\ mod\ 26$,
the formula of decryption: $D_n = (X_i - n)\ mod\ 26$,
and n = 5.

E denotes the encryption
D denotes the decryption
X denotes the value of the letter
n denotes the key value (shift value)

Note: "i" denotes the offset of the i-th number of the letters, as shown in the table below.

A	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z
00	01	02	03	04	05	06	07	08	09	10	11	12	13	14	15	16	17	18	19	20	21	22	23	24	25

The formula of encryption: $E_n = (X_i + n)\ mod\ 26$

Plaintext	Encryption	Ciphertext
G -> 06	(06+5) mod 26 =11	L
R -> 17	(17+5) mod 26=22	W
I -> 08	(08+5) mod 26=13	N
M -> 12	(12+5) mod 26=17	R
S -> 18	(18+5) mod 26=23	X
T -> 19	(19+5) mod 26=24	Y
A -> 00	(00+5) mod 26=05	F
D -> 03	(03+5) mod 26=08	I

The formula of decryption: $D_n = (X_i - n)\ mod\ 26$

Ciphertext	Decryption	Plaintext
L -> 11	(11-5) mod 26 =06	G
W -> 22	(22-5) mod 26=17	R
N -> 13	(13-5) mod 26=08	I
R -> 17	(17-5) mod 26=12	M
X -> 23	(23-5) mod 26=18	S
Y -> 24	(24-5) mod 26=19	T
F -> 05	(05-5) mod 26=00	A
I -> 08	(08-5) mod 26=03	D

b. Encrypt the message "**we are all together**" using a double transposition cipher with help of the row permutation (1,2,3,4,5) —> (2,4,1,3,5) and the column permutation

(1,2,3,4,5) —> (3,1,2,4,5). Explain the encryption and decryption procedure. Note: blank space can be denoted by “x”. (4%)

Original text in matrix format:

	1	2	3	4	5
1	w	e	x	a	r
2	e	x	a	l	l
3	x	t	o	g	e
4	t	h	e	r	x
5	x	x	x	x	x

Encryption Procedure:

- Row and Column Permutation:

	3	1	2	4	5
2	a	e	x	l	l
4	e	t	h	r	x
1	x	w	e	a	r
3	o	x	t	g	e
5	x	x	x	x	x

Encrypted Text: aexllethrxxwearoxtgexxxxx

Reverse row and column operations should be performed to decode the encrypted text.

c. The cryptographic hash function is denoted by H(m)→h where the input length can vary, and the output length is fixed. In this case, the output buffer size is 8.
Input: 0000, 0001, 0010, 0011, 0100, 0101, 0110, 0111, 1000, 1001, 1010.
What will be output? Is there any collision in the output? (3%)

Output: 0000, 0001, 0010, 0011, 0100, 0101, 0110, 0111, 0000, 0001, 0010

Yes, there will be collisions since the output buffer size is 8. Three outputs i.e., 0000, 0001, 0010 will suffer from collisions.

d. What is the difference between HTTP and HTTPS? (1.5%)

HTTPS is HTTP with encryption. The difference between the two protocols is that HTTPS uses TLS (SSL) to encrypt normal HTTP requests and responses. As a result, HTTPS is far more secure than HTTP.

e. Briefly explain symmetric vs asymmetric cryptography with an example. (3%)

In Symmetric cryptography, the same key is used for both encryption and decryption. Example of a symmetric algorithm: AES.
Whereas two different keys are used for the encryption (public key) and decryption (private key) respectively in asymmetric cryptography. Example of an asymmetric algorithm: RSA.

f. What is Kerckhoff's principle and what does it mean in practice? (1.5%)

Kerckhoffs' Principle states that the security of a cryptosystem must lie in the choice of its keys only, everything else (including the algorithm itself) should be considered public knowledge. In practice, this means that one cannot rely on the secrecy of an algorithm, secrecy must lie on keys.

g. The message is 010 111 100 000 101 and the key is 100 000 101 110 000. What will be the ciphertext if the One-Time Pad is used in the encryption process? (1.5%)

The ciphertext: 110 111 001 110 101

h. State three properties that must be present in a cryptographic hash function. (1.5%)

Three properties that must be present in a cryptographic hash function are as follows

1. collision resistance
2. pre-image resistance
3. second pre-image resistance

Question 3

Basics of IoT, CoAP, and AMQP (20%)

a. Project “A” of UiA aims to collect, store, and process sensitive patient data and to develop Machine learning (ML) algorithms to predict the physical well-being of patients. The data for project “A” will be collected from patients using non-wearable sensor devices at “X” hospital. After pre-processing at the hospital “X”, data will be transferred to UiA using a secured file-sharing system. The collected data from the hospital will be stored at UiA’s server. The researchers involved in the project will develop ML algorithms based on the received data stored at UiA’s server. Briefly discuss the privacy impact assessments (PIAs) process in the context of the “A” project. (7%)

The bellow steps need to be followed to perform PIA in Project “A”:

1. Identify the need for PIA
2. Describe information flow
3. Identify privacy risks
4. Identify privacy solutions
5. Record the PIA outcomes and sign-off
6. Integrate PIA outcomes in the project plan

Identify the need for PIA: Project A deals with sensitive patient data. Thus, PIA is necessary.

Describe information flow:

- The data will be collected from patients using sensors at hospital "X"
- Collected data will be processed at Hospital "X"
- Data will then be transferred to UiA using a secured file-sharing system
- Data received from Hospital "X" will then be stored on UiA's server
- Data will be accessed by researchers at UiA for the development of the ML algorithms.

Identify privacy risks: Personal information of patients can be exposed to the outside world which is a violation of the GDPR guideline.

Identify privacy solutions: Remove personal information of patients from data during the pre-processing stage.

Record the PIA outcomes and sign-off: Note down all possible information flows, possible impacts on individuals’ privacy, identify and recommend options for avoiding, minimizing, or mitigating negative privacy impacts.

Integrate PIA outcomes in the project plan: Outcome of privacy impact analysis and compliance checks, such as privacy management solutions or recommendations should be added to the project plan.

b. What are the best practices for the realization of the privacy by design (PbD) concept in smart devices? (3%)

The foundational principles of PbD need to be followed to implement PbD in smart devices. That is,

1. Proactive not reactive – Preventative, not remedial
2. Privacy as the default setting
3. Privacy embedded into the design
4. Full functionality – positive-sum, not zero-sum
5. End-to-end security – full lifecycle protection
6. Visibility and transparency – keep it open
7. Respect for user privacy – keep it user-centric

c. Why UDP is preferrable over TCP for voice communication? (1.5%)

Due to low latency, UDP is preferable over TCP for voice communication.

d. Vehicles are usually provisioned with many pseudonym certificates to sign messages transmitted by onboard equipment (OBE) devices within the vehicle. Why the same certificate should not be used for data communication over a long period? (1.5%)

The same certificate should not be used for data communication for a long period because the vehicle will become trackable over time.

e. Which layer of IEEE 802.15.4 is responsible for handling the transmission and reception of data packets? (1%)

MAC Layer.

f. Why CoAP is intended to use in resource-constrained devices? (2%)

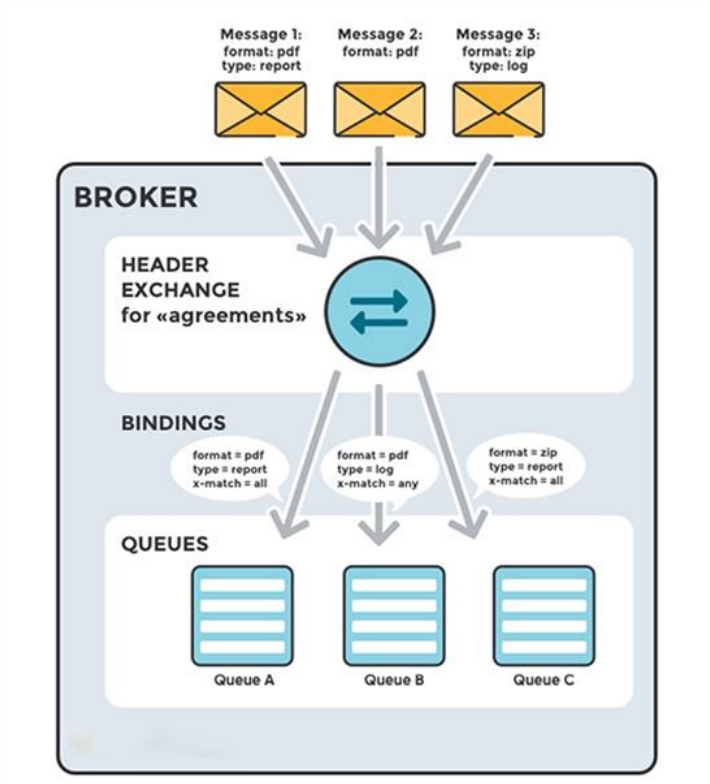
The CoAP is designed for reliability in low bandwidth and high congestion through its low power consumption and low network overhead. In a network with a lot of congestion or limited connectivity, CoAP can continue to work where TCP-based protocols such as MQTT fail to exchange information and communicate effectively. Due to this reason, CoAP is more suitable than MQTT for resource-constrained devices on the Internet of Things.

g. What are the key differences between CoAP confirmable message and CoAP non-confirmable message? (2%)

In CoAP confirmable message an ACK is expected whereas no ACK is required from the receiver side in CoAP non-confirmable message.

h. Where messages 1, 2, and 3 will be delivered in the below figure? (2%)

Message 1 will go to Queue A, message 2 will go to Queues A and B, and message 3 will be discarded.



Question 4

MQTT and Lab related Questions (20%)

a. Why MQTT protocol is considered as a scalable IoT protocol? (2%)

MQTT is a Publish (Pub) and Subscribe (Sub) protocol. In general, Pub/Sub protocol scales better than the conventional client-server approach. This is because operations on the Broker can be highly parallelized, and messages can be processed in an event-driven way. In addition, message caching and intelligent routing of messages are often decisive factors for improving scalability. Nevertheless, scaling up to millions of devices is a challenge. Such a high level of connections can be achieved with clustered broker nodes to distribute the load over more individual servers using load balancers.

b. Suppose a client has a transient session with the Broker (i.e., the clean-session flag is set to true) and has subscribed to the topic COVID_TEST_RESULT. When the client is offline, the Broker has received the message: **Negative** on the topic COVID_TEST_RESULT. Will the client receive the message: **Negative** when it reconnects with the Broker if the client's subscription to the topic COVID_TEST_RESULT has a QoS level of 2 and the message has a QoS level of 2? Give reasons. (3%)

Retain Message, Clean Session and QOS Table

Clean Session Flag	Retain Flag	Subsribe QOS	Publish QOS	Published Message Always Reeeived
True	False	0	0	No
True	False	0	1	No
True	False	1	0	No
True	False	1	1	No
False	False	0	0	No
False	False	0	1	No
False	False	1	0	No
False	False	1	1	Yes – All messages
True	True	0	0	Yes –Last Message only
True	True	0	1	Yes –Last Message only
True	True	1	0	Yes –Last Message only
True	True	1	1	Yes –Last Message only
False	True	0	0	Yes –Last Message only
False	True	0	1	Yes –Last Message only
False	True	1	0	Yes –Last Message only
False	True	1	1	Yes – All messages

Note: QOS 1 and QOS 2 produce same result. Therefore for QOS 1 in the table read 1 or 2.

The client will receive the "Negative" result if the "retain" flag is set to "true" when the publisher published it to the Broker. This is due to the reason that the Broker will keep the last message on that specific topic. The subscriber (offline and reconnects with a new session) will receive the last message, e.g., the "Negative" result. On the other hand, the subscriber (offline and reconnects with a new session)

won't receive the "Negative" result if the retain flag is set to "False" since the Broker will discard the message.

c. What is the difference between the "at least once" and the "exactly once" quality-of-service (QoS) levels in MQTT? Briefly explain their benefits/drawbacks. (4%)

QoS 1, i.e., at least once, guarantees that a message is delivered to the receiver at least once. The sender stores the message until it gets a PUBACK packet from the receiver that acknowledges receipt of the message. A message can be sent or delivered multiple times. The main benefit of QoS 1 over QoS 2 is that it delivers messages much faster than QoS 2. However, the application must tolerate duplicates and process them accordingly.

QoS 2, i.e., exactly once, is the highest level of service in MQTT. This level guarantees that the intended recipients receive each message only once. Therefore, QoS 2 is the safest and slowest quality service level. The guarantee is provided by at least two request/response flows (a four-part handshake) between the sender and the receiver. Therefore, using QoS 2, the application receives all messages exactly once. Nevertheless, It has limitations, such as protocol overhead and longer latency.

d. In MQTT-SN, clients connect to the Broker via an MQTT-SN Gateway. Why is gateway an essential part of MQTT-SN? How does a client can find an available MQTT-SN Gateway? (3%)

MQTT-SN clients connect to an MQTT server via an MQTT-SN gateway using the MQTT-SN protocol. Thus, the gateway acts as a bridge between MQTT-SN clients and an MQTT server. Its primary function is the translation between MQTT and MQTT-SN.

There are two ways for a client to find an available MQTT-SN gateway: periodic gateway advertisements and client search.

e. Find the topic for which the data is published and the QoS level specified for publishing.? (2%)

- ✓ client1.publish(temp, payload=12, qos=2, retain=False)

The client published a topic, "temp", with the QoS level is 2.

f. What do the following scripts mean to you? (2%)

- ✓ mqtt.Client("Python1", clean_session= True)
- ✓ client =mqtt.Client(client_name)

mqtt.Client("Python1", clean_session= True) creates client object with clean session. mqtt.Client(client_name) is an example of a client instance.

g. Two wildcard characters can be used for subscribing to multiple topics in MQTT. They are # and +. What makes them different? (2%)

The '+' indicates the single-level wildcard, whereas '#' denotes the multi-level wildcard.

h. A client may publish a message with the attribute "retained." When and why would you use "retained"? (2%)

A retained message is a standard MQTT message with the retained flag set to true. The Broker stores the last retained message and the corresponding QoS for that topic.

A retained message makes sense when you want newly-connected subscribers to receive messages immediately (without waiting until a publishing client sends the next message).

Question 5

Threat Modeling (20%)

a. State the benefits of "threat modeling" in a project. (2%)

Threat modeling should be part of the development process. For example, Microsoft, which has developed the STRIDE threat modeling tool, has threat modeling as a central part of its Security Development Lifecycle (SDL) process.

"Applying a structured approach to threat scenarios during design helps a team more effectively and less expensively identify security vulnerabilities, determine risks from those threats, and establish appropriate mitigations." – Microsoft SDL documentation

Therefore, the threat model is an excellent aid in achieving a better and more secure system design, and it is also an essential input for the security testing process.

b. What is a "threat actor"? (2%)

A threat actor is an entity that may carry out a malicious action toward some asset.

The threat actor is also called intruder, perpetrator, attacker, etc.

c. Describe the pros/cons of the "breadth-first" approach. (2%)

Breadth-first is advantageous when one wants coverage over the whole system. The disadvantage is that this approach may not be detailed enough to uncover all threats.

d. What are the "strategies" for dealing with the identified threats? (2%)

Some strategies for dealing with threats:

- Remove the threat (remove functionality)
- Mitigate the threat
  - Reducing exposure when possible
  - Technical provision to prevent attacks (security controls etc.)
  - May include a technical provision to lessen the impact of an attack
  - May include a technical provision that makes an attack harder to carry out
- Accept the risk
  - There will always be risks
  - If you understand the risk, you decide that it is acceptable to take the chance
- Transfer the risk
  - Insurance
  - Some other party

e. Consider the scenario shown in the below figure. The system consists of health data (heart rate and breath rate) monitoring smartwatch that communicates with a mobile phone using Bluetooth. The mobile phone is also connected to a cloud-based health information storage (i.e., stores the readings pushed by the smartwatch) via an App. The App uses a web interface, and the App does not know or care if the connection uses WiFi or a cellular data link. With respect to the given scenario, identify a threat for each of the threat categories in STRIDE (spoofing, tampering, repudiation, information disclosure, denial of service, elevation of privilege) and propose suitable countermeasures to address each of the identified threats. (12%)

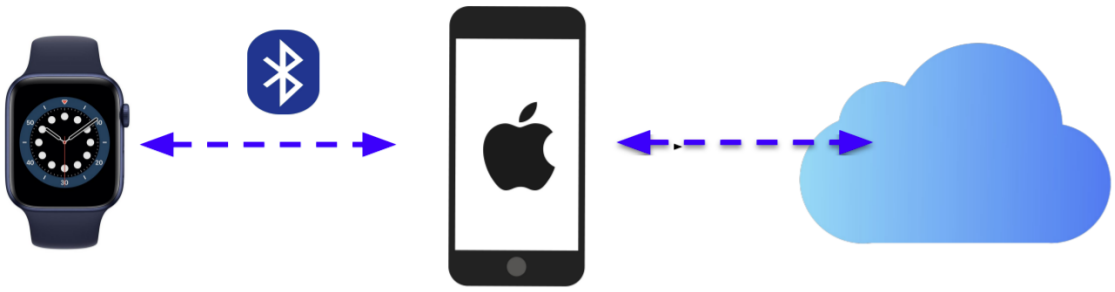


Figure: Threat modeling scenario.

STRIDE threats:

1. Smartwatch (Boundary A)

    1.1. Spoofing: the smartwatch may be spoofed (false smartwatch identifier)

    1.2. Tampering: Falsifying data

    1.3. Repudiation: Denial of consumed data, produced data

    1.4. Information disclosure: Leaking health data

    1.5. Denial of Service: Disabling some function of the smartwatch

    1.6. Elevation of Privilege: It seems complicated to see how this can be done.

2. Bluetooth

    2.1. Spoofing: smartwatch and/or smartphone may be impersonated

    2.2. Tampering: Falsifying data

    2.3. Repudiation: Denial of consumed data, produced data

    2.4. Information disclosure: Leaking health data

    2.5. Denial of Service: Disrupt communications

2.6. Elevation of Privilege: It seems complicated to see how this can be done.

3. Smartphone (Boundary B)

3.1. Spoofing: smartphone may be impersonated

3.2. Tampering: Falsifying data

3.3. Repudiation: Denial of consumed data, produced data

3.4. Information disclosure: Leaking health data, subscription data

3.5. Denial of Service: Disrupt communications/service

3.6. Elevation of Privilege: It seems complicated to see how this can be done.

4. HTTP

4.1. Spoofing: smartphone/cloud server may be impersonated

4.2. Tampering: Falsifying data

4.3. Repudiation: Denial of consumed data, produced data

4.4. Information disclosure: Leaking health data, subscription data

4.5. Denial of Service: Disrupt communications/service

4.6. Elevation of Privilege: It seems complicated to see how this can be done.

5. Cloud Server (Boundary C)

5.1. Spoofing: cloud server may be impersonated

5.2. Tampering: Falsifying data

5.3. Repudiation: Denial of consumed data, produced data

5.4. Information disclosure: Leaking health data, subscription data

5.5. Denial of Service: Disrupt communications/service

5.6. Elevation of Privilege: It seems complicated to see how this can be done.

To address the threats:

- Harden the cloud service

- Harden the smartphone app

- Harden the smartwatch

- Full Bluetooth security (data confidentiality, data integrity, and authentication)
- Use TLS for HTTP connection
    - If one-way TLS, then ensure that App is fully authenticated (password)